WEEK 7 TASK WIRESHARK & NETWORK ANALYSIS REPORT

Question 1: Analyse packet1.pcap and find the flag.

The packet capture file packet1.pcap was analysed using Wireshark. During inspection, multiple ICMP Echo (ping) packets were observed. One of the packets contained suspicious encoded data within the payload section.

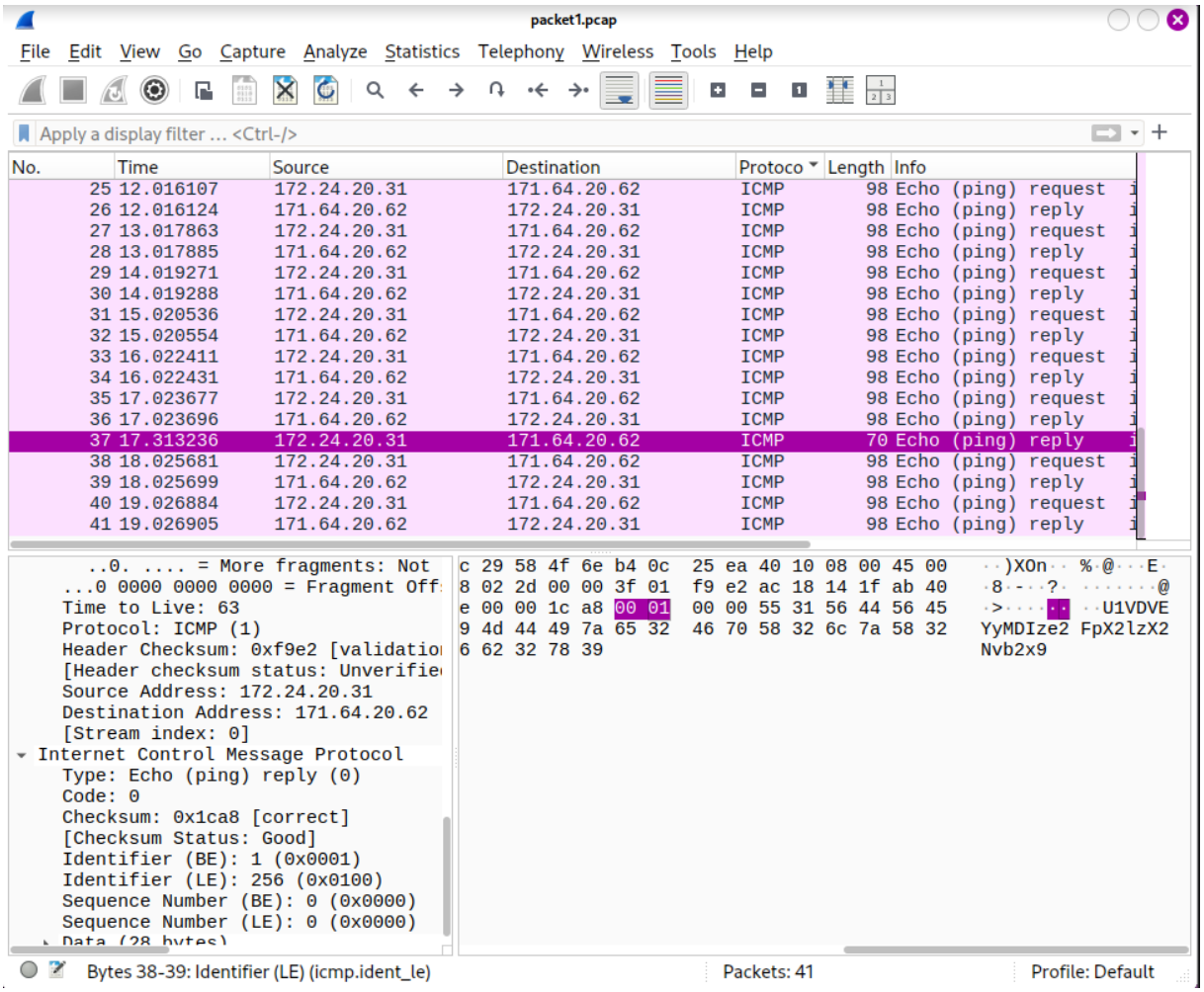


Figure 1: As shown in Figure 1 (page 1), the ICMP packet details reveal a string

This string "U1VDVEYyMDIze2FpX2lzX2Nvb2x9" appears to be encoded using Base64 encoding. To verify, the string was decoded using an online Base64 decoder. The decoded result is shown in Figure 2.

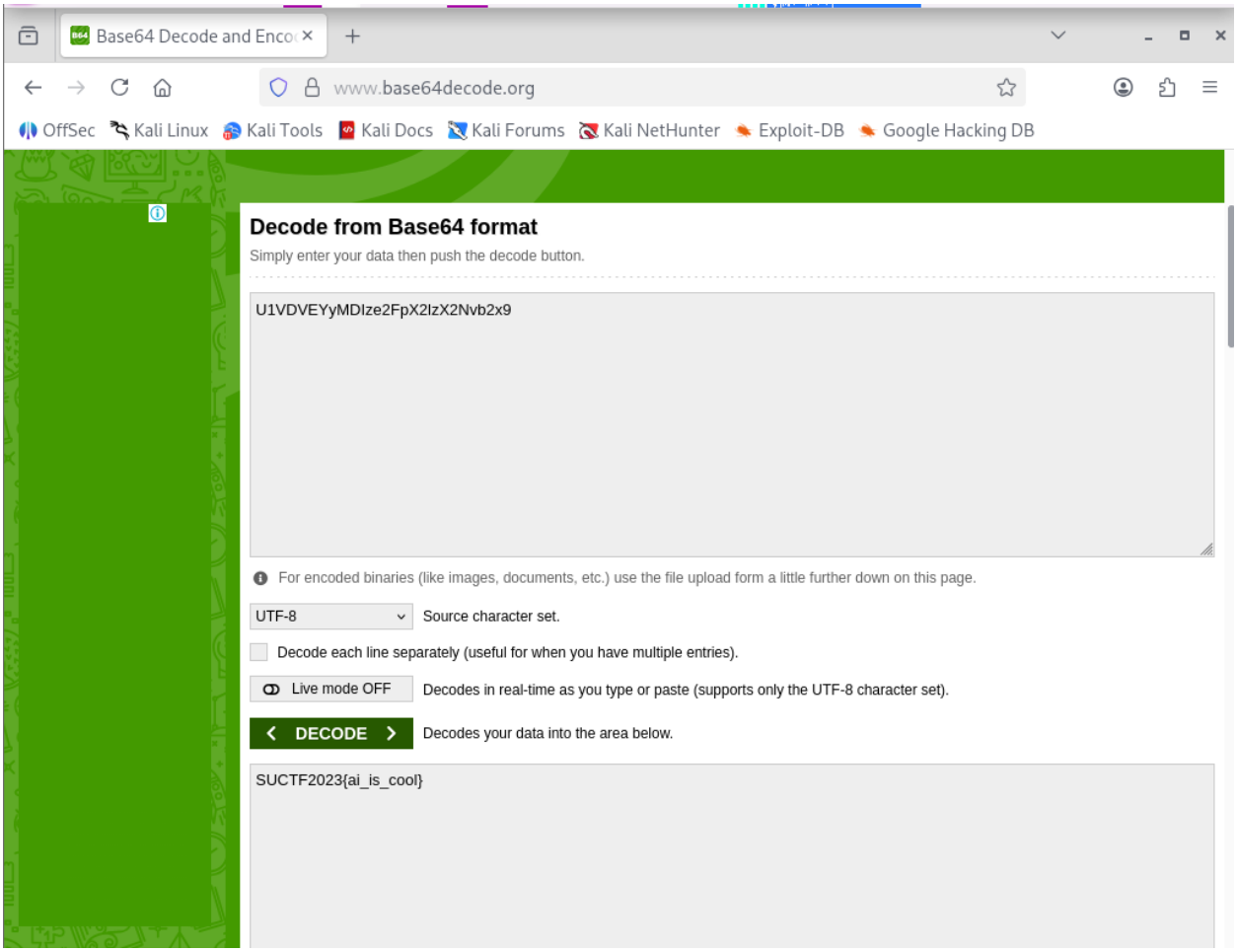


Figure 2: Successful decode the Base64 encoding.

After decoding, I succcesfully found the flag.

FLAG1: SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.

In the second packet capture file, traffic analysis revealed activity over TCP protocol, particularly involving HTTP communication.

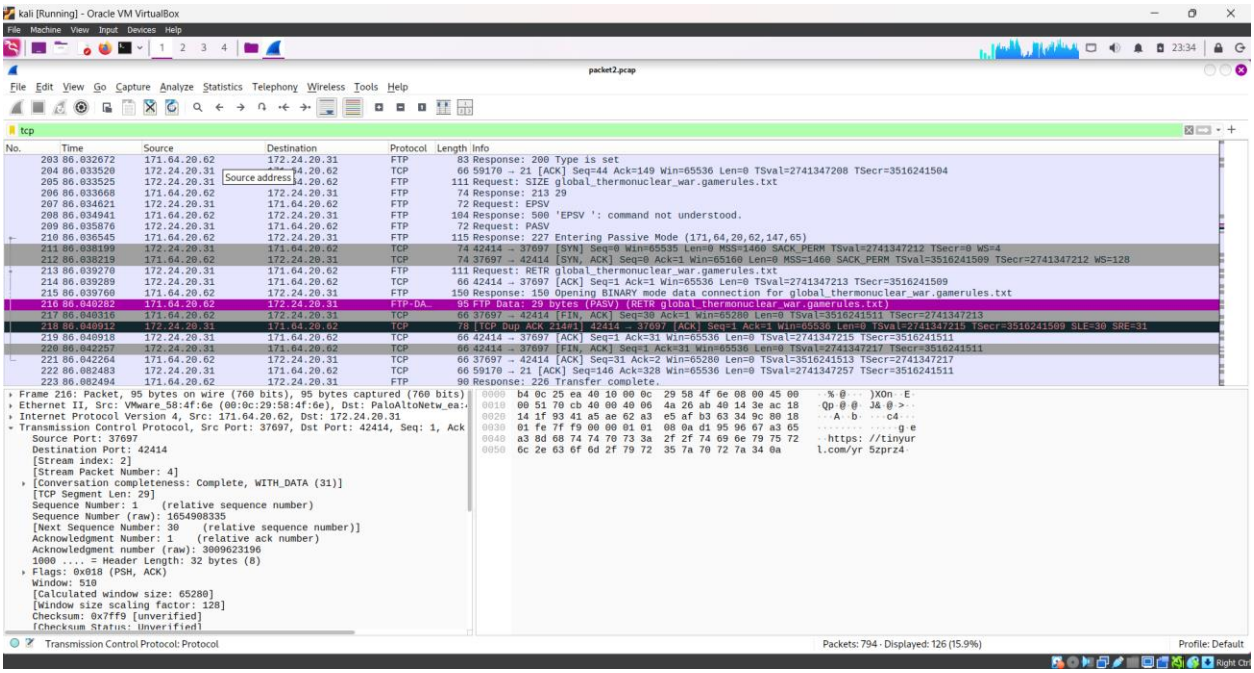


Figure 3: Suspicious URL was identified within the packet stream.

As shown in Figure 3, a suspicious URL was identified within the packet stream. This URL appeared unusual and potentially linked to hidden data or a vulnerability.

Steps taken:

-Extracted the URL from the TCP stream.

-Opened the URL in a web browser.

-The webpage displayed encoded/obfuscated text.

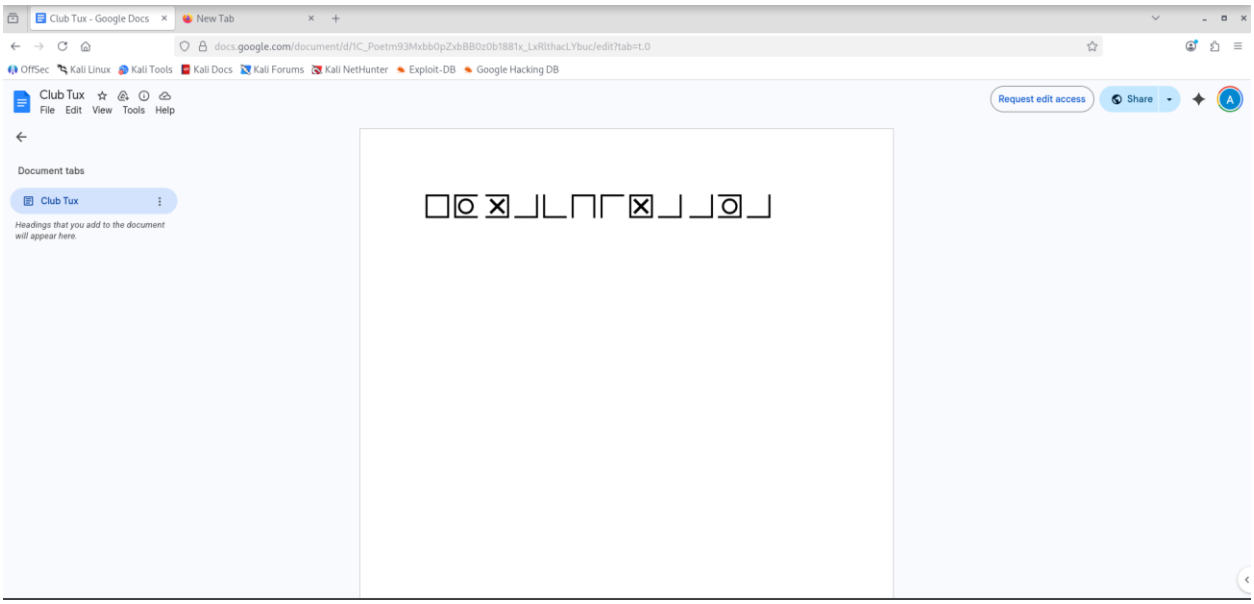


Figure 4: Successful found google drive file.

After further inspection and decoding, the hidden text was successfully identified. Thus, the flag was retrieved from the external web content linked within the packet capture.

Question 3: Interpret an Nmap Output

PORT STATE SERVICE VERSION

- 21/tcp open ftp vsftpd 2.3.4 22/tcp open ssh
- OpenSSH 5.3p1 80/tcp open http
- Apache 2.2.8 139/tcp open netbios-ssn
- 445/tcp open microsoft-ds Windows 7 Professional 7601 Service Pack 1

Questions:

1. What can an attacker do with each port?

   Port 21 (FTP): An attacker can attempt to log in using common or default credentials (brute force). Specifically, for vsftpd 2.3.4, they can trigger a hidden backdoor by sending a specific string to the server, granting them instant system-level access.

   Port 22 (SSH): Attackers can perform high-speed brute-force attacks to guess user passwords. If successful, they gain an encrypted remote terminal to execute commands directly on the operating system.

   Port 80 (HTTP): This is a gateway to web applications. Attackers can scan for hidden files, directories, or vulnerabilities like SQL Injection and Cross-Site Scripting (XSS) to steal database information or hijack user sessions.

   Port 445 (SMB): An attacker can enumerate network shares to find sensitive documents or backups. On older systems like Windows 7, this port is the primary target for sending malicious packets that exploit the kernel to gain full control of the machine.

2. What vulnerabilities are likely present based on the version?

   vsftpd 2.3.4: This version is notorious for a Backdoor Command Execution vulnerability (CVE-2011-2523). Logging in with a username ending in ” :) “ triggers a listener on port 6200, allowing a root shell.

   OpenSSH 5.3p1: This version is significantly outdated and likely contains vulnerabilities related to User Enumeration and potential Denial of Service (DoS) attacks.

   Apache 2.2.8: Being nearly 15 years old, it is susceptible to numerous "Old CVEs" involving memory exhaustion, header parsing vulnerabilities, and prying into protected server information.

   Windows 7 (SMB): The most critical threat is MS17-010 (EternalBlue). This allows unauthenticated attackers to execute code in the kernel, making it a favorite for worm-like ransomware.

3. Which one is the highest risk and why?

   Port 445 (Windows 7 / SMB) is the highest risk.

   Reason: Windows 7 is End-of-Life (EOL), meaning it no longer receives official security updates from Microsoft. Because port 445 (SMB) runs with the highest possible privileges (SYSTEM), a successful exploit like EternalBlue gives an attacker complete control over the computer without needing any valid credentials.

4. What attack path can be built from this?

   Reconnaissance: Use Nmap to identify port 445 is open and confirms the OS is Windows 7.

   Weaponization: Select the ms17_010_eternalblue exploit module within a framework like Metasploit.

   Delivery/Exploitation: Launch the exploit against the target IP over port 445.

   Action on Objectives: Once a session is established, the attacker can dump local password hashes, install a persistent backdoor, or pivot to other computers on the same network.

5. What should be the remediation?

   Operating System Upgrade: Decommission Windows 7 and upgrade to a modern, supported OS like Windows 10 or 11.

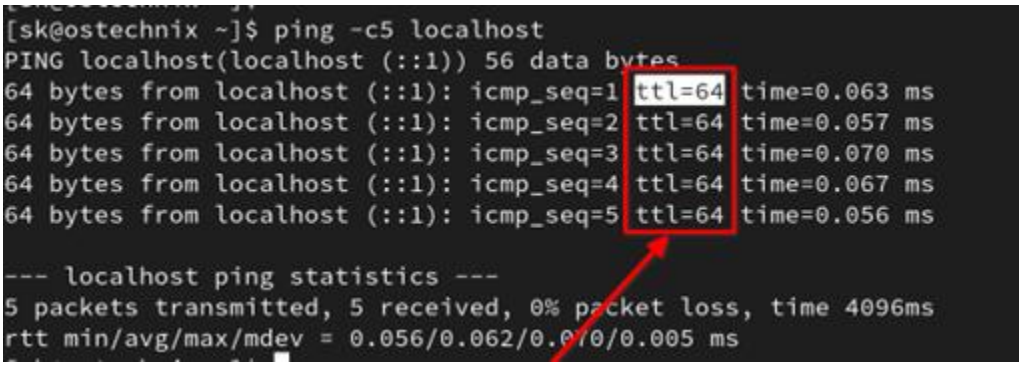
   Service Updates: Upgrade vsftpd, OpenSSH, and Apache to their current stable versions to patch known security holes.

   Network Hardening: Implement a firewall to block inbound traffic to port 445 from the internet. If SMB is required for internal use, restrict it to specific authorized IP addresses.

   Disable Unnecessary Services: If FTP (Port 21) is not strictly required for business operations, it should be disabled entirely to reduce the attack surface.

Question 4: Identify the OS (OS Fingerprinting) - TTL

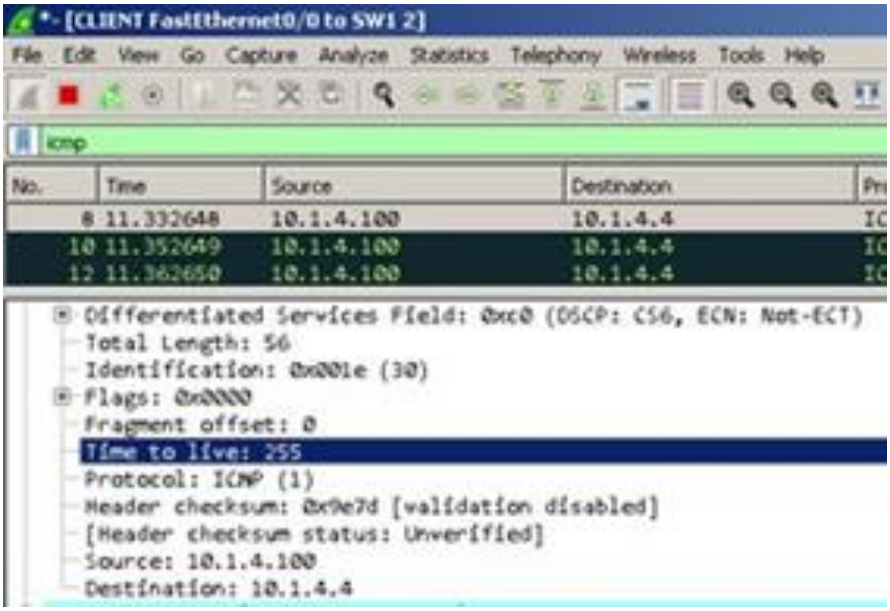
Image 1



Answer: Linux / Unix

The ping output shows a TTL of 64. This value is the standard default for most Linux distributions and Unix-based systems.

Image 2



Answer: Network Device (Cisco Router/Switch)

The Wireshark capture clearly displays a Time to Live of 255 in the IP layer. A TTL of 255 is the default value for many network infrastructure devices, such as Cisco routers and switches.

Image 3:

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

Answer: Windows

The ICMP echo reply shows a TTL of 128. This is the signature default TTL value for nearly all modern versions of the Microsoft Windows operating system.

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named “Ghostcat”.

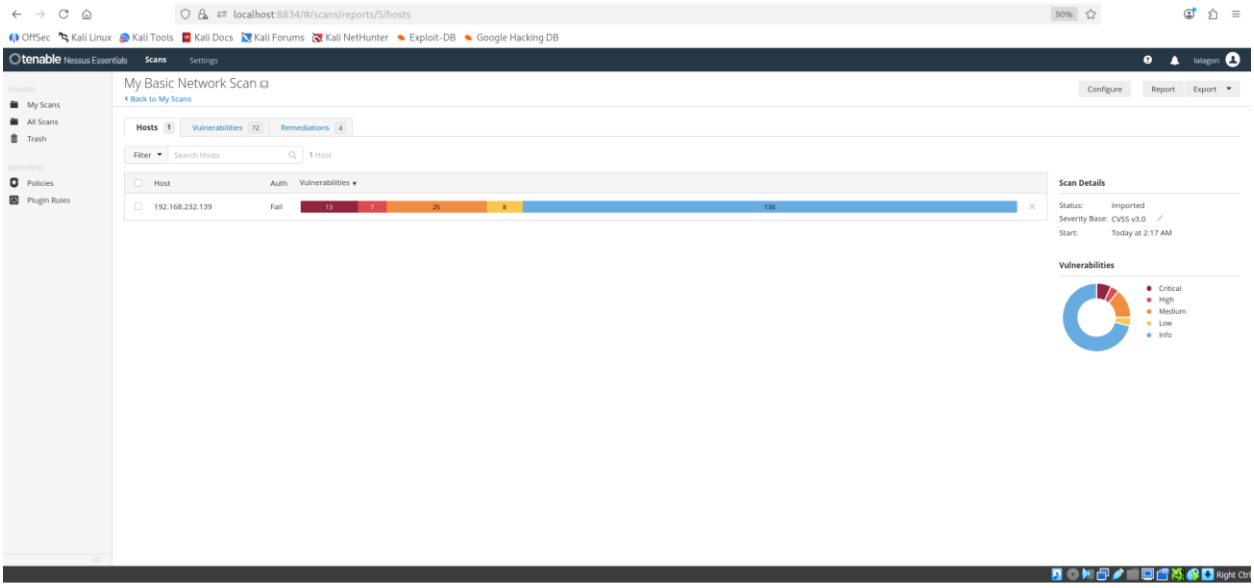


Figure 5: The file Network_Scan.nessus was imported into Nessus successfully

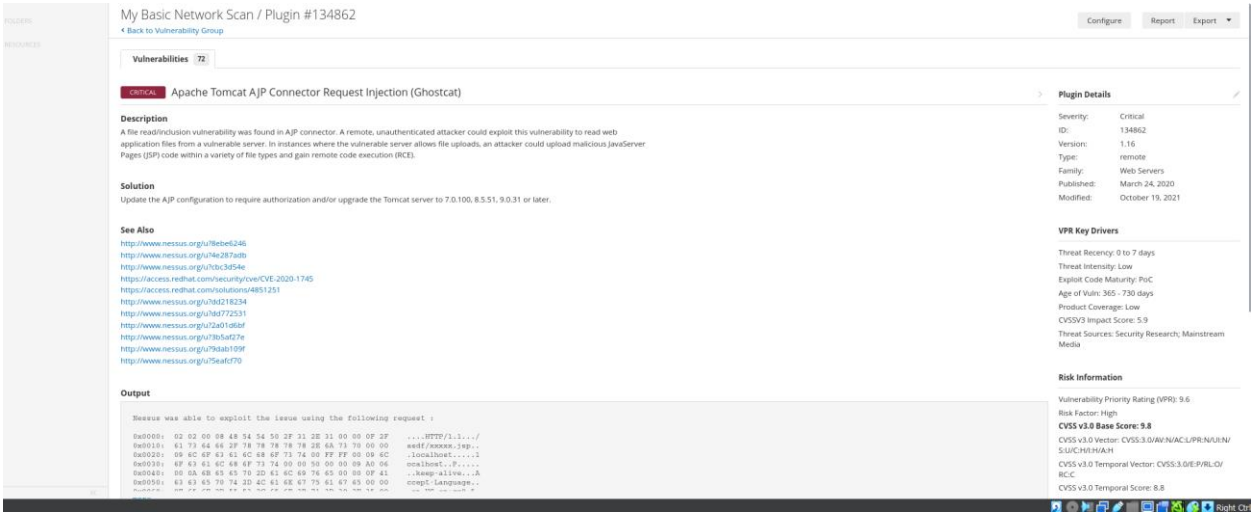


Figure 6: Successfully found vulnerability for Ghostcat.

1. What is the affected Port number:
   8009

2. What is the Affected protocol:
   AJP (Apache JServ Protocol)

3. What is the CVSS Score of vulnerability found?
   9.8 (Critical)

4. Can you find any exploit related to this vulnerability?
   Yes. There are several, including a Metasploit module (auxiliary/admin/http/tomcat_ghostcat) and various Python scripts available on GitHub and Exploit-DB.

5. Find CVE for this vulnerability.
   CVE-2020-1938, CVE-2020-1745